

Sicurezza

CdL in Informatica – L31

Lezione 5 Authentication

Prof. Emiliano Casalicchio
Department of Computer Science
Sapienza University of Rome



SAPIENZA
UNIVERSITÀ DI ROMA



Argomenti trattati

- Authentication: its capabilities and limitations
- The three bases of authentication: knowledge, characteristics, possessions
- Strength of an authentication mechanism
- Authentication security issues



Definition

- The basis of computer security is controlled access:
 - **Someone** is authorized to take **some action** on **something**.
- we need to be sure **who the someone** is
- Determining a **subject** identity consists of two separate steps:
 - **Identification** is the act of asserting who a subject is.
 - **Authentication** is the act of proving that asserted identity is correct: that the subject is who it (he or she) claims.



Authentication

Identities

- often well known, predictable, or guessable

Authentication

- should be private.
- confirms that you are who you purport to be (with the identity)
- if the authentication process is not strong enough, it will not be secure.

Authentication mechanisms use any of three qualities (or a combination) to confirm a user's identity:

- Something the user ***knows***.
- Something the user ***is***. (**biometrics**)
- Something the user ***has***. (**token**)



Authentication Based on Phrases and Facts: Something You Know

Widly used authentication mechanism

Difficulties of use:

- *Use.*
 - Supplying a password for each access to an object can be inconvenient and time consuming.
- *Disclosure.*
 - to an unauthorized individual, the object becomes immediately accessible.
 - changes the password to re-protect the object, the user must inform any other legitimate users (or NHE) of the new password
- *Revocation.*
 - To revoke one user's access right to an object, someone must change the password, thereby causing the same problems as disclosure.
- *Loss.*
 - it may be impossible to retrieve a lost or forgotten password.
 - The system administrators can provide a new password



Attacking Passwords: 12 steps an attacker might try to determine a password

1. no password
2. the same as the user ID
3. derived from the user's name or ID
4. on a common word list (for example, "password," "secret," "private") plus common names and patterns (for example, "qwerty," "aaaaaa")
5. contained in a short college dictionary
6. contained in a complete list of English words
7. contained in common non-English-language dictionaries
8. contained in a short college dictionary with capitalizations ('PaSsWoRd') or substitutions (digit 0 for letter O, 1 for l, and so forth)
9. contained in a complete English dictionary with capitalizations or substitutions
10. contained in common non-English dictionaries with capitalizations or substitutions
11. obtained by brute force, trying all possible combinations of alphabetic characters
12. obtained by brute force, trying all possible combinations from the full character set



Passwords strength

The 12 steps are time consuming;

- time is not a limiting factor for attacker

Every password can be guessed;

- **password strength** is determined by how many guesses are required.



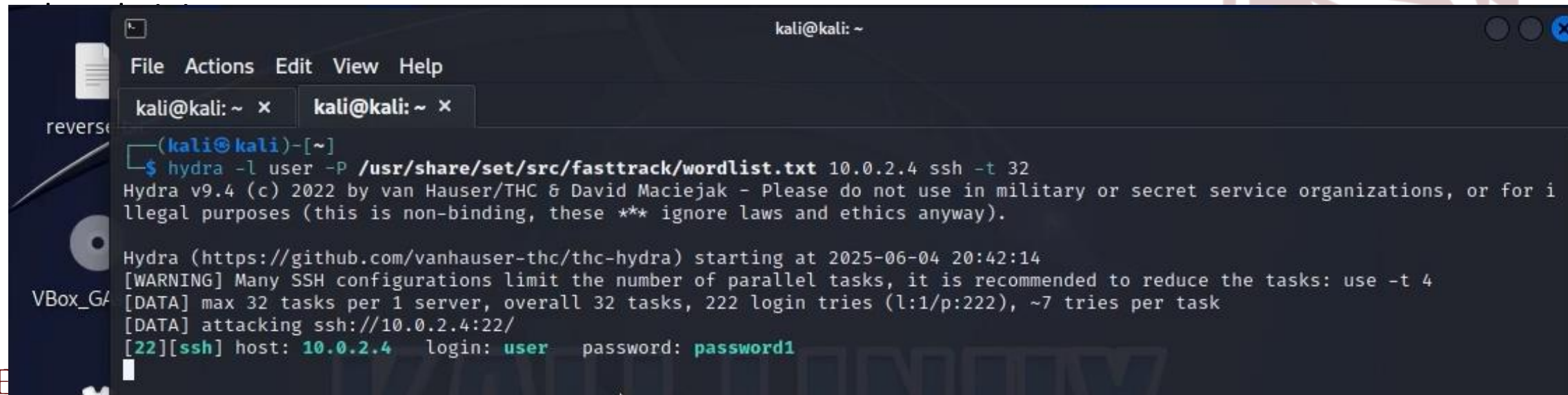
A short sad story

- Password is a cheap and efficient authentication means
- Password are chosen by humans (the weak part)
 - Predictable patterns
 - Negligency
- Attackers leverage humans weakness for guessing
 - Dictionary attack
 - Rainbow table attack
 - Exhaustive search



Dictionary Attacks

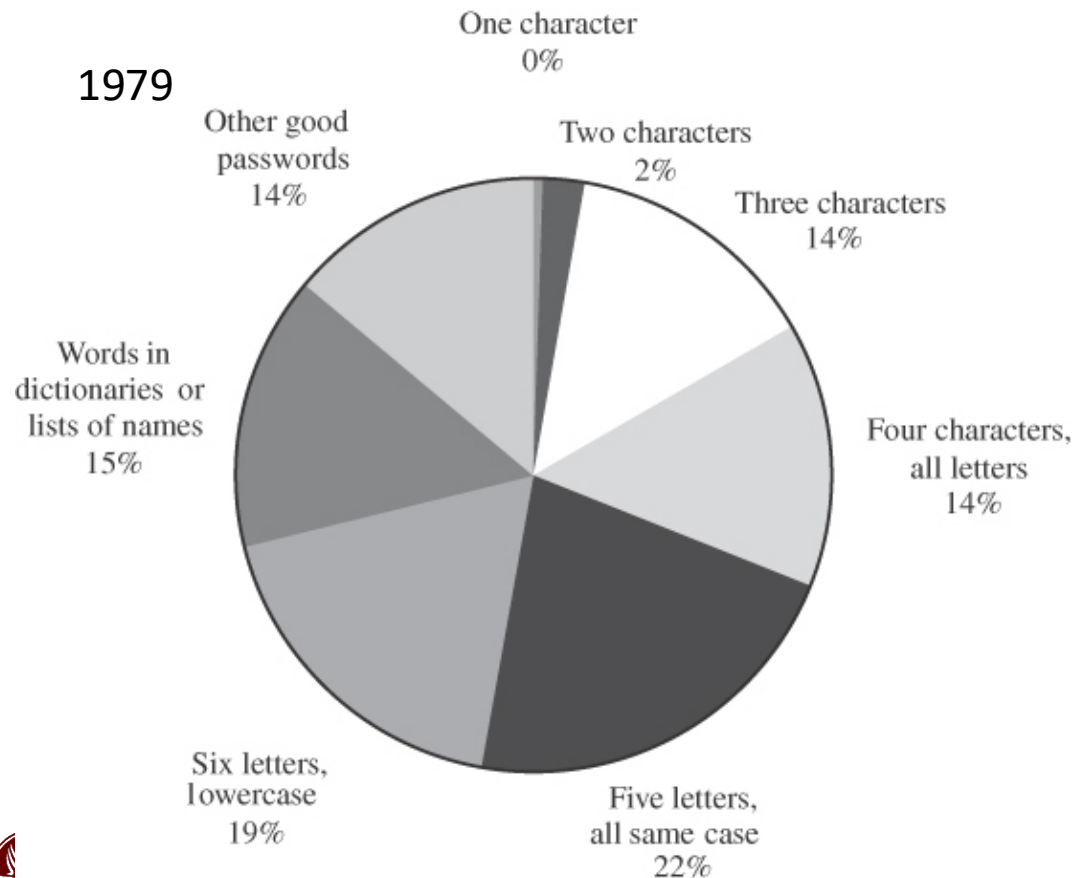
- Several network sites post dictionaries of
 - phrases, science fiction character names, places, mythological names, Chinese words, Yiddish words, and other specialized lists.
- There are utilities that allow to scan a system for commonly used passwords
 - E.g. Hydra <https://github.com/vanhauser-thc/thc-hydra>



```
kali@kali: ~  
File Actions Edit View Help  
kali@kali: ~ x kali@kali: ~ x  
(kali@kali)-[~]  
$ hydra -l user -P /usr/share/sets/src/fasttrack/wordlist.txt 10.0.2.4 ssh -t 32  
Hydra v9.4 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for i  
llegal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-06-04 20:42:14  
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4  
[DATA] max 32 tasks per 1 server, overall 32 tasks, 222 login tries (l:1/p:222), ~7 tries per task  
[DATA] attacking ssh://10.0.2.4:22/  
[22][ssh] host: 10.0.2.4 login: user password: password1
```

Inferring Passwords Likely for a User

- Users use guessable passwords, from 1979 (Morris and Thompson) to today the picture didn't change



2019 (500M pwd dataset)

- about 30% of users chose passwords of fewer than seven characters
- nearly 50% of people used names, slang words, dictionary words, or trivial passwords—consecutive digits, adjacent keyboard keys, and so on
- most popular passwords included “12345,” “123456,” “1234567,” “password,” and “iloveyou” in the top ten

Guessing Probable Passwords

- Humans usually selects passwords that ARE NOT
 - long
 - Uncommon
 - hard to spell or to pronounce
- Penetrators searching for passwords realize these very human characteristics and use them to their advantage
 - To reduce the search space
 - E.g. If people prefer short passwords to long ones, the penetrator will plan to try all passwords but to try them in order by length. From the English alphabet there are only $26^1 + 26^2 + 26^3 = 18278$ (not case sensitive) passwords of length 3 or less.



Defeating concealment

- OS store passwords in a obscured form (concealment)
 - E.g. encrypted or hashed
- Concealed passwd – User ID are stored in a table
 1. User provide the plaintext passwd
 2. The OS apply the concealment algorithm and compare the result with the passwd stored in a table
- If an attacker obtain this table (or a table), it can offline
 - build a **RAINBOW TABLE** of concealed and plaintext passwd from a dictionary
 - Compare the concealed passwd in the rainbow table with the passwd table
 - Obtain the match



Plaintext	
Identity	Password
Jane	qwerty
Pat	aaaaaa
Phillip	oct31witch
Roz	aaaaaa
Herman	guessme
Claire	aq3wm\$oto!4

Conceiled (encryption or hashing)	
Identity	Password
Jane	0x471aa2d2
Pat	0x13b9c32f
Phillip	0x01c142be
Roz	0x13b9c32f
Herman	0x5202aae2
Claire	0x488b8c27

Rainbow
Table

Original Password	Encrypted Password
asdfg	0x023c94fc
p@55w0rd	0x04ff38d9
aaaaaa	0x13b9c32f
password	0x2129f30d
qwerty	0x471aa2d2
12345678	0x4f2c4dd8
123456	0x5903c34d
aaaaa	0x8384a8c8



Defeating concealment: countermeasures

- Another issue with concealment is that same passwd have the same concealed value
- To counter rainbow table and same password threats is introduced the concept of **SALT**
- A **salt** is an extra data field that is different for each user;
 - it can be something related to the account or user in some way, such as the date the account was created or a part of the user's name.
 - It could be a random value
 - The salt value is joined to the password before the combination is transformed by concealment. In this way, Pat+aaaaaa has a different concealment value from Roz+aaaaaa,



**Rainbow
Table**

Original Password	Encrypted Password
asdfg	0x023c94fc
p@55w0rd	0x04ff38d9
aaaaaa	0x13b9c32f
password	0x2129f30d
qwerty	0x471aa2d2
12345678	0x4f2c4dd8
123456	0x5903c34d
aaaaa	0x8384a8c8

Conceilement + Salt

Identity	ID+password (not stored in table)	Stored Authentication Value
Jane	Jan+qwerty	0x1d46e346
Pat	Pat+aaaaaa	0x2d5d3e44
Phillip	Phi+oct31witch	0xc23c04d8
Roz	Roz+aaaaaa	0xe30f4d27
Herman	Her+guessme	0x8127f48d
Claire	Cla+aq3wm\$oto!4	0x5209d942

With Salt, a dictionary of password + a password file is useless for the attacker, he cannot build a rainbow table .. He must build a mammut table for all the possible salt values





Figure 3.3 UNIX Password Scheme

Vantaggi nell'uso del Salt

- Impedisce che password uguali siano “visibili”
 - avranno salt diversi e quindi hash values diversi
- Rende impossibile scoprire se un utente ha usato la stessa password su due o piu' sistemi
- Aumenta la difficoltà degli attacchi offline di un fattore 2^b dove b e' il numero di bit del salt



Exhaustive Attack

- In an **exhaustive** or **brute force** attack, the attacker tries all possible passwords, usually in some automated fashion



Countermeasures

- Stronger passwords rules
- Use of other information to use with passwords
 - Location
 - Security Questions



Password Cracking - summary

Dictionary attacks

- Develop a large dictionary of possible passwords and try each against the password file
- Each password must be hashed using each salt value and then compared to stored hash values

Rainbow table attacks

- Pre-compute tables of hash values for all salts
- A mammoth table of hash values
- Can be countered by using a sufficiently large salt value and a sufficiently large hash length

Password crackers exploit the fact that people choose easily guessable passwords

- Shorter password lengths are also easier to crack (avg 6-8 chars 2012/70K)



Authentication Based on Biometrics: Something You Are

- fingerprint
- hand geometry (shape and size of fingers)
- retina and iris (parts of the eye)
- voice
- handwriting, signature, hand motion
- typing characteristics
- blood vessels in the finger or hand
- face
- facial features, such as nose shape or eye spacing

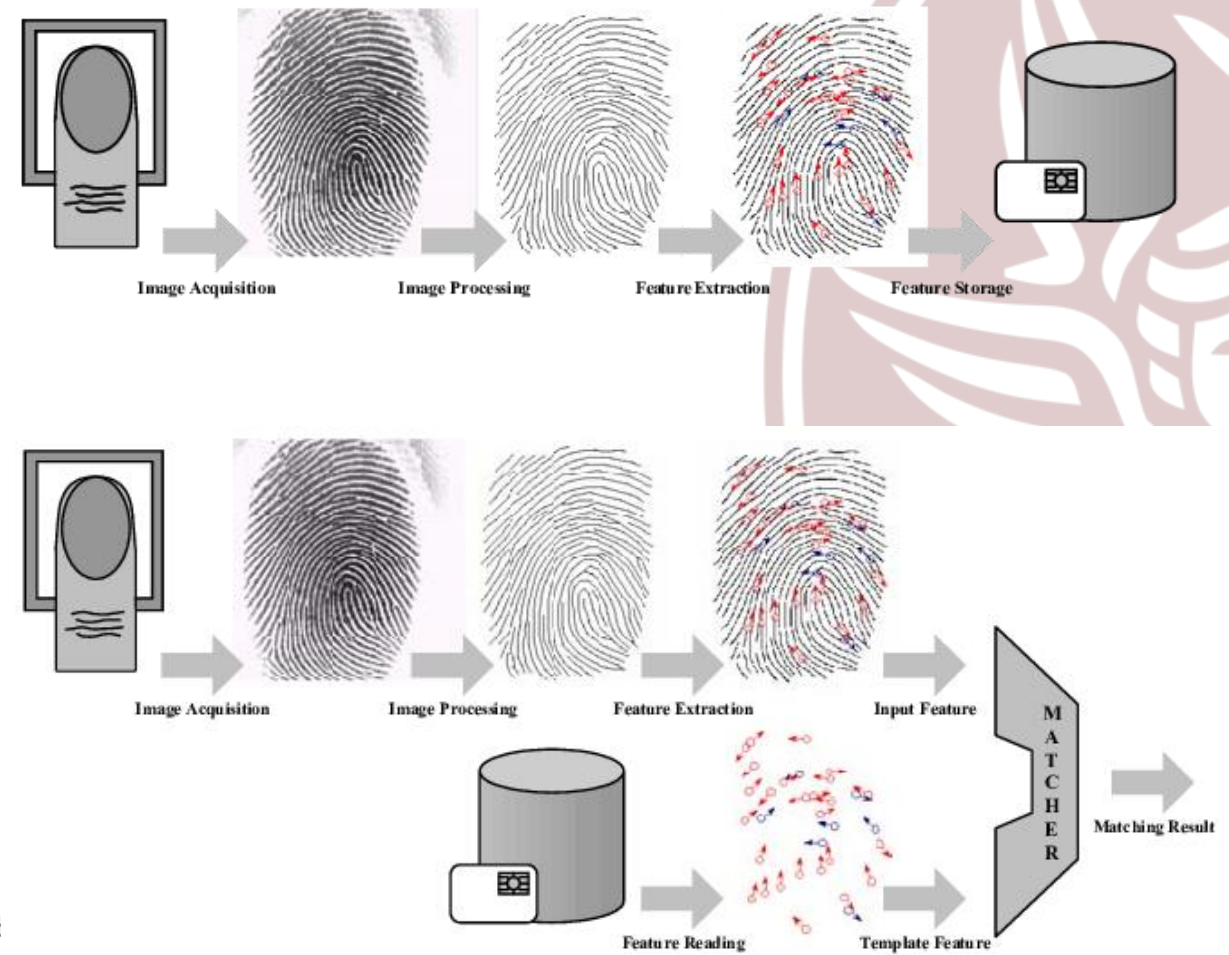
Advantages over passwords

- cannot be lost, stolen, forgotten, or shared and is always available
- some biometric characteristics can be forged, but the degree of difficulty is high

How Biometric Authentication works

- It requires a pattern or **template** that represents measurement of the characteristic
1. registration with the system, i.e. the system records the template of subject features.
 2. when the subject use a biometric for authentication, a current set of measurements is taken and compared to the template

M. Fons, F. Fons and E. Canto, "Design of an Embedded Fingerprint Matcher System," *2006 IEEE International Symposium on Consumer Electronics*, St. Petersburg, Russia, 2006, pp. 1-6, doi: 10.1109/ISCE.2006.1689467.



How Biometric Authentication works (cont'd)

Not exact matching with the template is needed

- Authentication succeeds if the match is “close enough,” meaning it is within a predefined tolerance
 - E.g., 90% of the values match or if each parameter is within 5% of its expected value.

When a screening system compares something it has with something it is measuring, we call this a **dichotomous system or test**: Either there is a match or there is not.

Reference Standard for Describing Dichotomous Tests	Is the Person Claimed	Is Not the Person Claimed
Test is positive. (There is a match.)	True Positive (tp)	False Positive (fp)
Test is negative. (There is no match.)	False Negative (fn)	True Negative (tn)



Success of a dichotomous test (Standard measures)

	Is the Person Claimed	Is Not the Person Claimed
Test is positive. (match.)	tp	fp
Test is negative. (no match.)	fn	tn

Sensitivity [$tp/(tp+fn)$]

- measures the degree to which the test selects those whose names correctly match the person sought. It is the proportion of positive results among all possible correct matches

Specificity [$tn/(fp+tn)$]

- measures the proportion of negative results among all people who are not sought

Accuracy [$(tp+tn)/(tp+tn+fp+fn)$]

- measures the degree to which the test correctly flags the condition or situation

Prevalence [$(tp+fn)/(tp+tn+fp+fn)$]

- tells us how common a certain condition or situation is

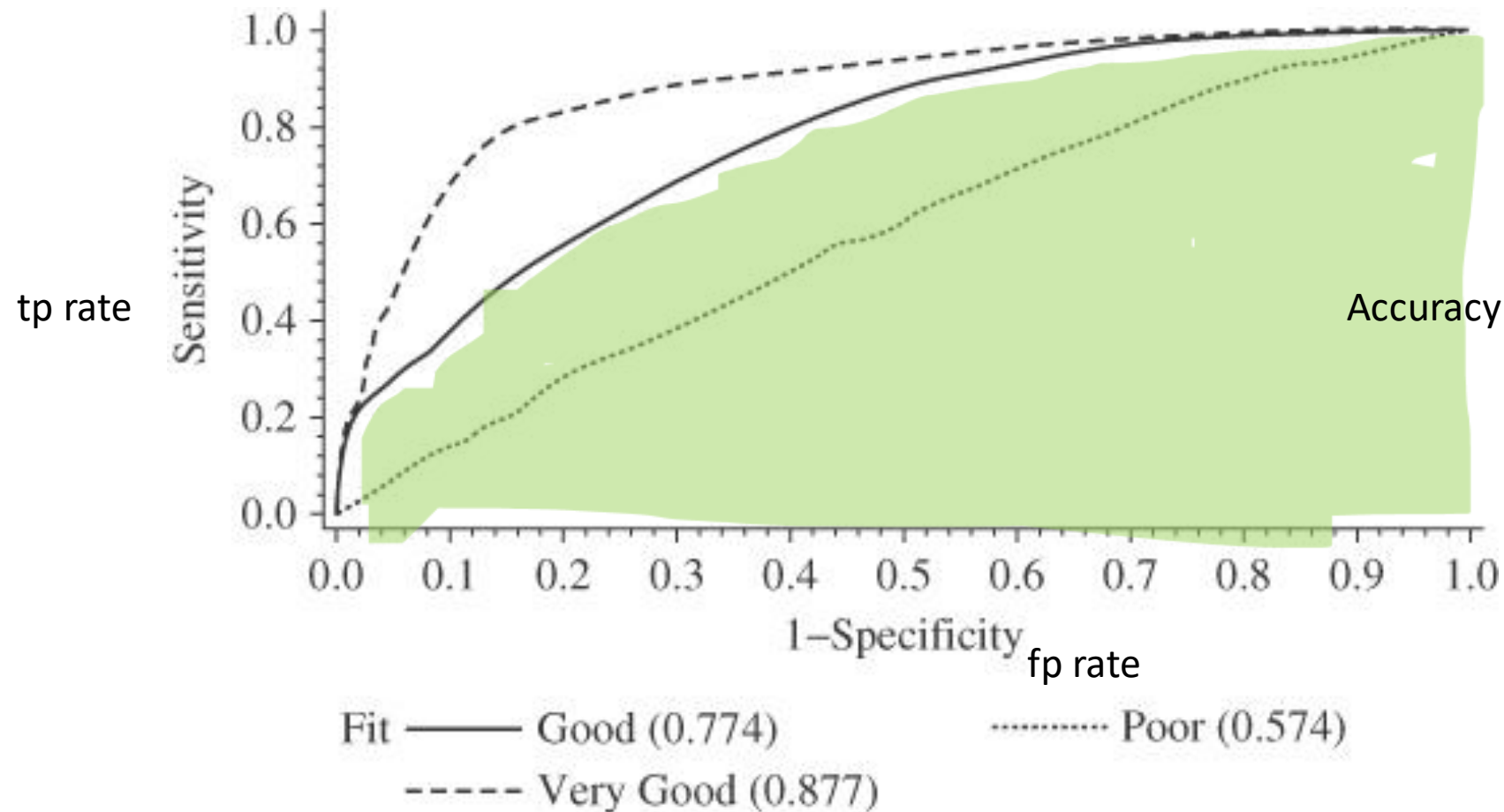


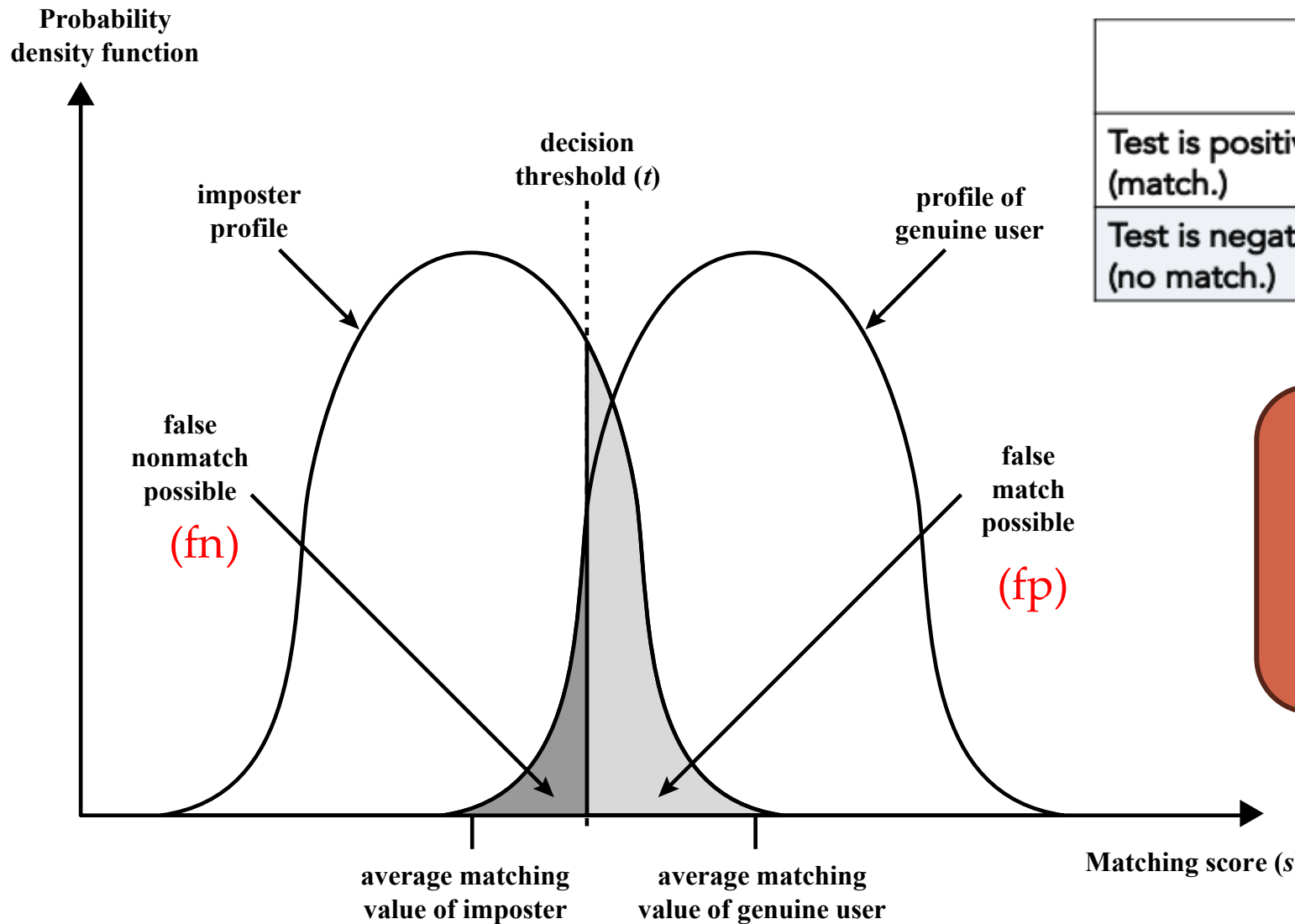
Sensitivity and specificity

- describe how well a test discriminates between cases with and without a certain condition
- are statistically related: when one increases, the other decreases.
 - you cannot simply reduce or remove false positives; such an action is sure to increase the false negatives.
 - you have to find a balance between an acceptable number of false positives and false negatives.
- A *receiver operating characteristic (ROC) curve* is a graphical representation of the trade-off between the false negative and false positive rates.



ROC curve: trade off between fp rete and tp rate





	Is the Person Claimed	Is Not the Person Claimed
Test is positive. (match.)	tp	fp
Test is negative. (no match.)	fn	tn

fn are critical for the usability

fp are critical for security of the authentication mechanism,

Figure 3.10 Profiles of a Biometric Characteristic of an Imposter and an Authorized Users In this depiction, the comparison between presented feature and a reference feature is reduced to a single numeric value. If the input value (s) is greater than a preassigned threshold (t), a match is declared.

Problems with Use of Biometrics

- *Intrusive*
- *Single point of failure*
- Use *sampling* and establish a *threshold* for acceptance
- *False readings* still occur
- The *speed* at which a recognition must be done limits accuracy
- *Forgeries* are possible



Accuracy of Biometrics

Is a mechanism that **does not discriminate**:

- the process is biased, caused by the balance between sensitivity and selectivity: some people are more likely to pass and others more likely to fail

Measuring the accuracy of biometric authentication is difficult because **the authentication is not unique**

- We can compute fp & fn for a test population
- We cannot extrapolate the results for the world



Biometrics: Identification vs Authentication

Weak for Identification

- We search a match through all the template
- Unless every template is unique, that is, no two people have the same values, the system cannot uniquely identify subjects

Strong for Authentication

- We match a specific template
- as long as an imposter is *unlikely* to have the same biometric template as the real user, the system can authenticate, that is, keep out most imposters
- In remote authentication forgery probability increase (weakness increase)



Authentication Based on Tokens: Something You Have

- passive tokens (key, photo): the contents of the token never change
- active token can have some variability or interaction with its surroundings
 - Could interact through magnetic stripe or radio transmission and change the value of the token (e.g. transportation cards)
- static token remains fixed
 - Keys, identity cards, passports, credit and other magnetic-stripe cards, and radio transmitter cards (called RFID devices)



Skimming

- Tokens are vulnerable to an attack called skimming
- **Skimming** is the use of a device to copy authentication data surreptitiously and relay it to an attacker



casali@uniroma1.it



Source: From the internet

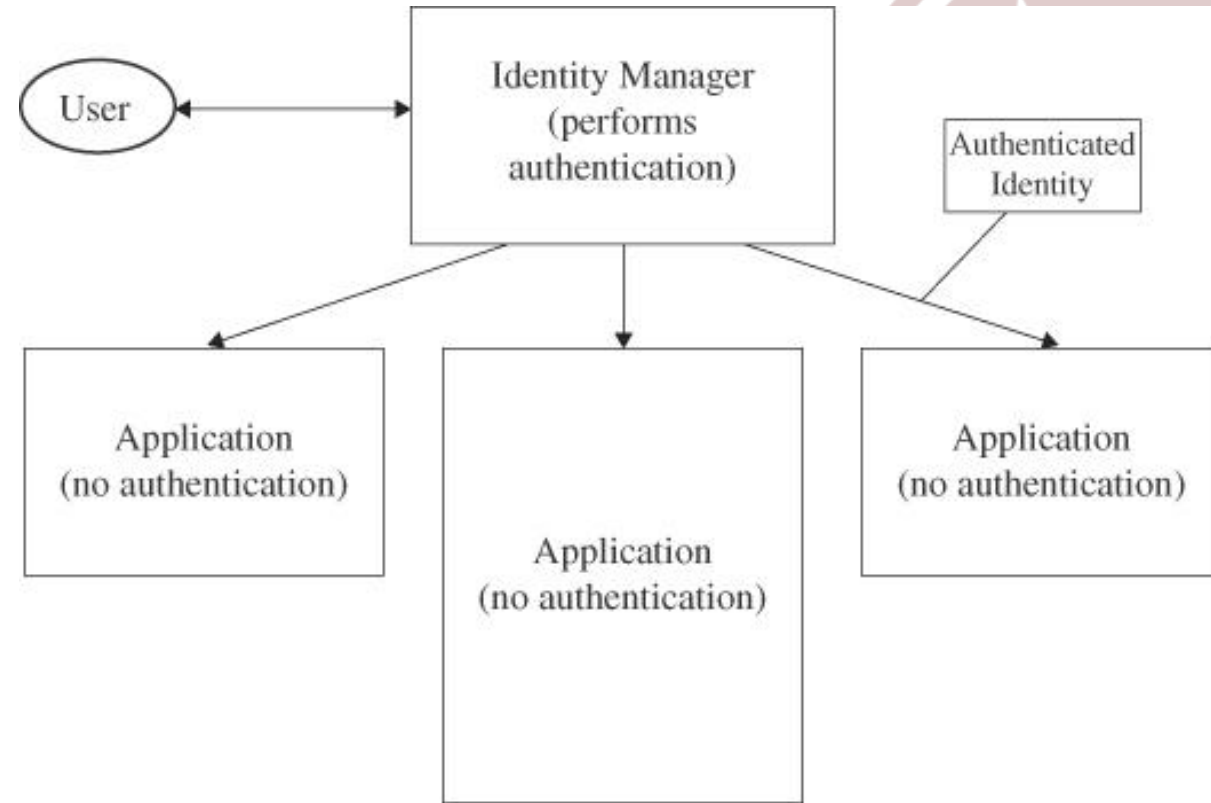
Dynamic token: the value changes

- is a device that generates an unpredictable value that we might call a pass number
 - change numbers at a particular interval, for example, once a minute;
 - change numbers when you press a button
 - compute a new number in response to an input, sometimes called a challenge
- Eliminate the skimming vulnerability
 - The value of the token is valid only for a single authentication transaction



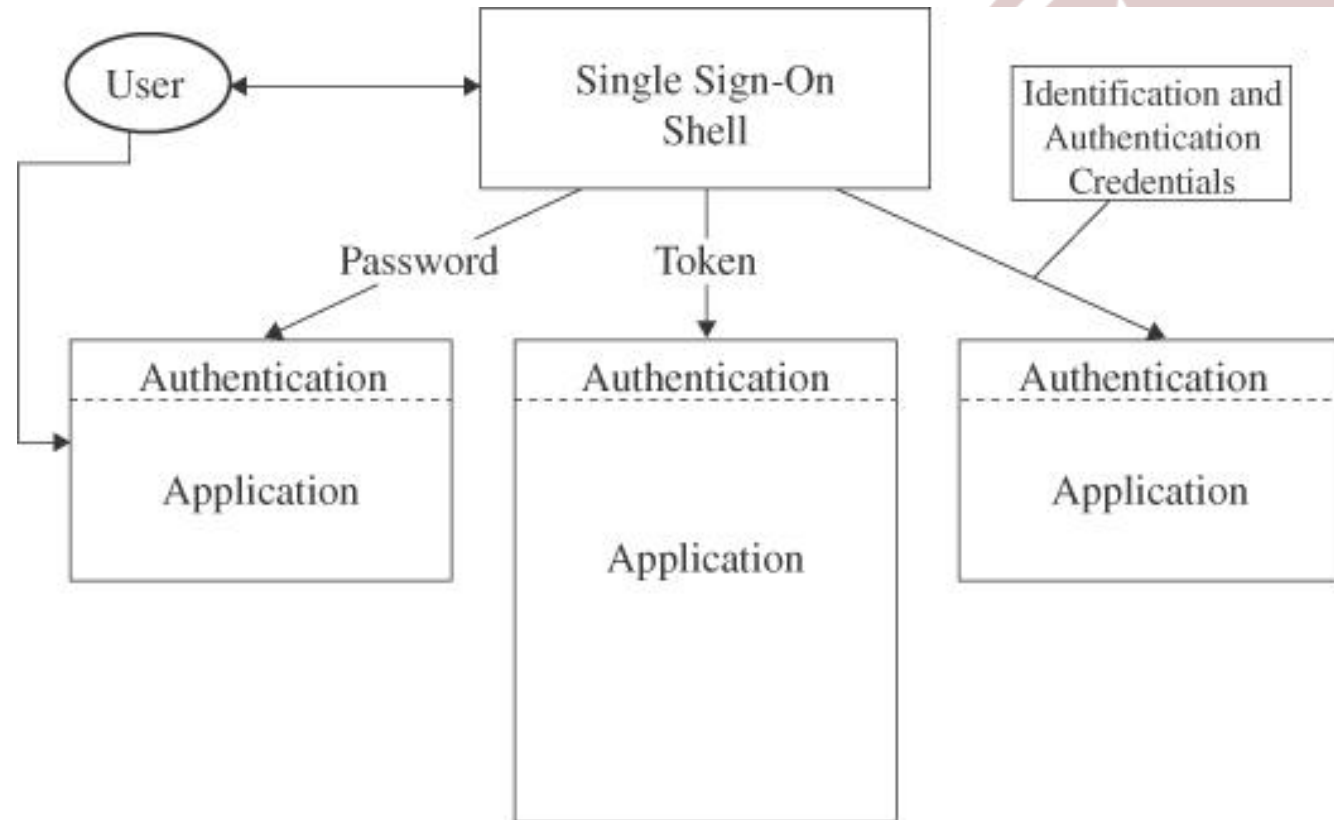
Federated Identity Management (FIM)

- A FIM scheme is a union of separate identification and authentication systems.
- A federated scheme maintains one profile with one authentication method
 - Separate systems share access to the authenticated identity database.
- Authentication is performed in one place
 - separate processes and systems determine that an already authenticated user is to be activated.



Single sign-on

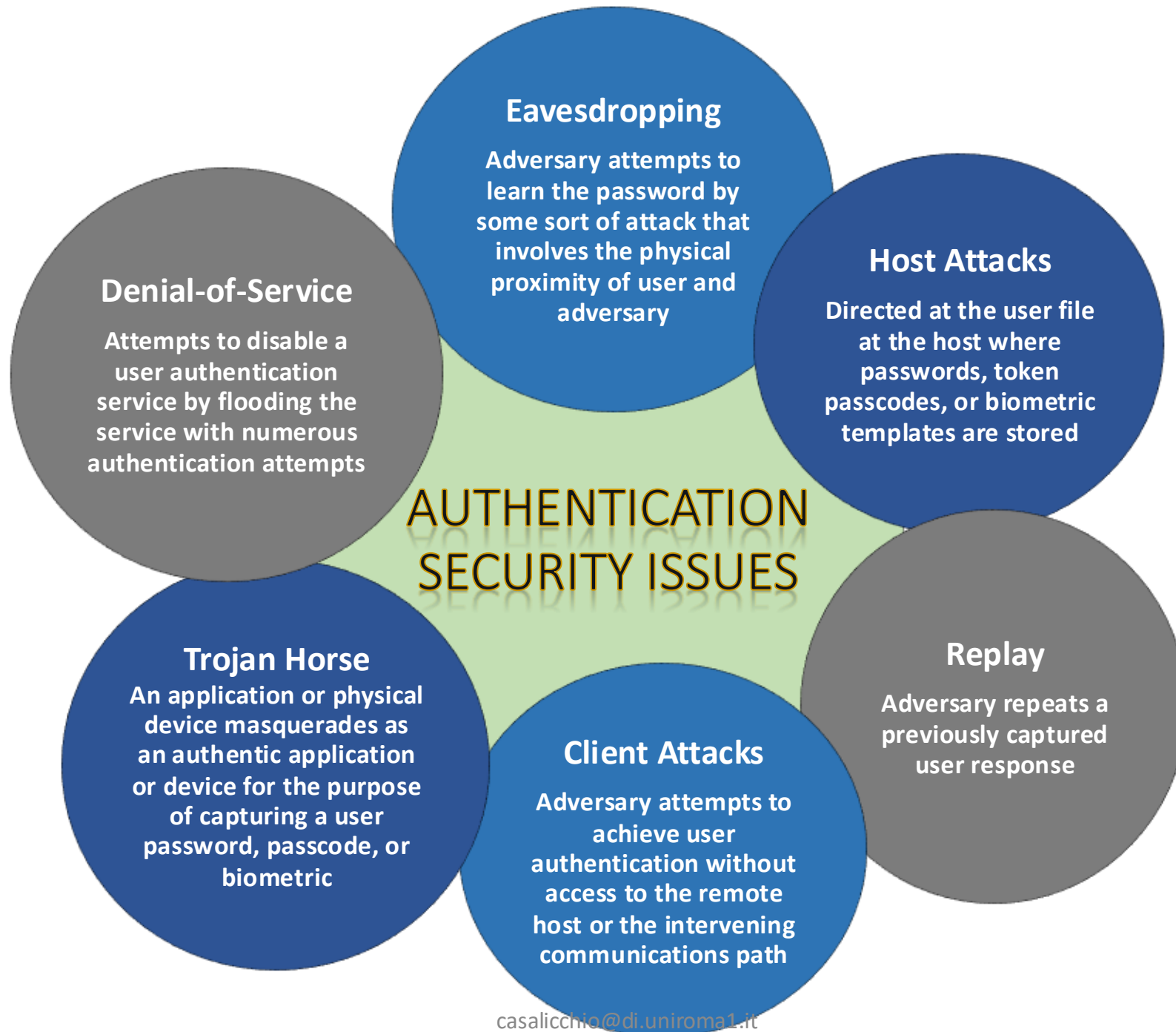
- an umbrella procedure to which you log in once per session (for example, once a day).
- The umbrella procedure maintains your identities and authentication codes for all the different processes you access
- The single sign-on process passes specific authentication details to the services



Multi-factor authentication

- Is about combining authentication information and approaches
 - E.g. 2FA could combine ID & password (syk) with dynamic token (syh)
- It is stronger, but managing more authentication systems add complexity, that is not necessarily good for security
 - even if multifactor authentication is superior to single factor, we do not know which value of n makes n -factor authentication optimal
 - From a usability point of view, large values of n may lead to user frustration and reduced security.
- Adding more factors does not improve security if those factors are compromised or weak
 - In 2FA, the token value sent by email or text message can be intercepted by an attacker





Client Attack

- An adversary attempts to achieve user authentication without access to the remote host or to the intervening communications path
 - The adversary attempts to masquerade as a legitimate user
- Password Auth
 - Attack: Password guessing, brute force (exhaustive search)
 - Defense: complex password (large entropy), limited attempts
- Token Auth
 - Attack: brute force
 - Defense: large entropy passcode by token, physically acquisition of the token
- Biometric Auth
 - Attack: false match
 - Defense: select biometrics with large entropy, limited attempts



Host Attack

- Directed at the user file at the host where passwords, token passcodes, or biometric templates are stored
- Password
 - Attack: dictionary, brute force, theft
 - Defense: hashing, large entropy, protection of password file/db
- Token:
 - Attack: passcode theft
 - Defense: same as password, + onetime passcode
- Biometric
 - Attack: biometric template theft
 - Defense: static - biometric device authentication; dynamic - challenge-response protocol



Eavesdropping Attack

- Refers to an adversary's attempt to learn the password by observing the user
- Password
 - Attack: sholder surfing, keylogging
 - Defense: diligence, quick revoke, multi-factor auth
- Token:
 - Attack: theft, physical copy
 - Defense: same as password
- Biometric
 - Attack: copying or imitating the biometric;
 - Defense: dynamic more resistant; static - biometric device authentication;



Eavesdropping Attack

- Refers to an adversary's attempt to learn the password by observing the user
- Password
 - Attack: sholder surfing, keylogging
 - Defense: diligence, quick revoke, multi-factor auth
- Token:
 - Attack: theft, physical copy
 - Defense: same as password
- Biometric
 - Attack: copying or imitating the biometric;
 - Defense: dynamic more resistant; static - biometric device authentication;



Trojan horse Attack

- An application or physical device masquerades as an authentic application or device for the purpose of capturing a user password, passcode, or biometric
- Password, Token, Biometric
 - Attack: installation of rogue client or capturing devices
 - Defense: authentication of client, software, devices;



Replay Attack

- Involve an adversary repeating a previously captured user response
- Password, Token, Biometric
 - Attack: replay captured responses
 - Defense: challenge-response protocols, multi-factor auth, one time passcode



Denial of Service Attack

- Attempts to disable a user authentication service by flooding the service with numerous authentication attempts
 - Could be directed to a specific user leveraging lockout mechanisms
- Password, Token, Biometric
 - Attack: lockout by multiple attempt
 - Defense: multifactor authentication protocol with token



